

**Cyber Threat Analysis in the Financial Sector**

**Dennis Kalinin**

**Robert Morris University**

**Undergrad Capstone**

**November 23<sup>rd</sup>, 2025**

## **Introduction**

PNC Financial Services Group is one of America's largest diversified financial institutions, providing everything from retail banking to wealth management. However, the reality is that managing vast amounts of sensitive financial data comes with serious risks. Customer information, transaction records, and proprietary business data flow through PNC's online platforms and in-branch systems daily, making them an attractive target for cybercriminals.

This report examines three major cybersecurity threats that keep security teams at financial institutions like PNC up at night: SQL Injection, Phishing Attacks, and Ransomware. We chose these threats for good reason; they are not only widespread but also incredibly damaging to both operations and bottom lines. Each threat operates differently: SQL Injection exploits technical vulnerabilities in web applications, Phishing manipulates human psychology, and Ransomware holds entire systems hostage. Understanding how these attacks work is essential to maintaining strong cybersecurity defenses and staying compliant with regulations such as PCI DSS, NIST, and GLBA.

## **Risks and Impact**

SQL Injection remains a persistent nightmare for financial institutions that rely heavily on web-based applications. Here is how it works: attackers find unsecured input fields on websites and inject malicious SQL commands. This gives them a backdoor into backend databases. For a bank like PNC, the consequences could be catastrophic, unauthorized access to customer data, manipulated account balances, or even control over internal administrative systems.

From a technical standpoint, SQL Injection attacks compromise both the integrity and confidentiality of financial data. Attackers can view, modify, or delete sensitive records at will. The financial fallout is severe: lost funds, hefty legal penalties, and compliance violations. Nevertheless, there is also a human cost. When customers hear that their bank has been breached, trust evaporates. In today's world, people expect their financial institutions to be fortresses of security (OWASP, 2023). A single vulnerability could expose millions of customer records, which is why robust database input validation, parameterized queries, and regular penetration testing are not optional; they are essential.

Phishing is deceptively simple, which is precisely what makes it so dangerous. Attackers craft emails, text messages, or websites that look remarkably like legitimate communications from trusted organizations like PNC. The goal? Trick people into handing over their credentials or downloading malware. Once attackers have those credentials, they can access corporate systems, initiate fraudulent transactions, or steal confidential data.

What makes Phishing particularly insidious is its ability to sidestep traditional security measures by exploiting human nature. The Verizon Data Breach Investigations Report (2024) found that over 36% of financial breaches involved phishing as the primary attack vector. The financial damage is twofold: direct monetary losses from fraudulent transfers and the substantial costs of remediation and customer compensation. The damage to reputation can be even worse. Financial institutions live and die by their credibility, and a successful phishing attack can shatter years of built-up trust. This is

why employee awareness training, multifactor authentication, and advanced email filtering are not just best practices; they are business necessities.

Ransomware has emerged as one of the most disruptive threats facing the financial sector. The attack is brutally straightforward: malicious software encrypts vital organizational data, and attackers demand payment for the decryption keys. Until the ransom is paid (and sometimes even after), business operations grind to a halt. Imagine PNC's ATM networks going dark, online banking platforms becoming inaccessible, or internal payment systems freezing up.

The technical consequences are that the immediate data becomes inaccessible, and systems go down. However, the financial impact is staggering. IBM's 2024 Cost of a Data Breach Report found that the average ransomware incident in the financial industry costs over \$5 million. That includes ransom payments, recovery costs, and lost business. The social impact is equally damaging. Customer confidence plummets, and public image takes a serious hit. The situation has gotten even worse with the rise of "double extortion," where attackers not only encrypt data but also threaten to leak it publicly (IBM, 2024). For institutions like PNC, comprehensive backup strategies, network segmentation, and real-time threat detection have moved from "nice to have" to "must have."

## **Cases and Data**

Looking at recent history, we can see how these three threats have played out in devastating real-world scenarios. These incidents offer valuable lessons about what happens when even well-resourced organizations face sophisticated cyberattacks.

The 2008 Heartland Payment Systems breach remains one of the most significant SQL Injection attacks in history. Attackers exploited unpatched database vulnerabilities, gaining access to approximately 130 million credit card numbers. Cybersecurity journalist Brian Krebs noted that "the Heartland breach cost the company more than \$140 million in settlements and remains one of the most damaging SQL Injection incidents ever recorded" (Krebs, 2009). Even though this happened over a decade ago, it is still taught as a cautionary tale in cybersecurity courses worldwide.

More recently, British Airways learned this lesson the hard way in 2018, when an SQL injection attack compromised 380,000 customer transactions. The UK's Information Commissioner's Office reported that "British Airways was fined £20 million for failing to protect customer payment data" (ICO, 2019). These cases prove that SQL Injection is not just a theoretical threat; it continues to cause real damage to major organizations.

In 2014, JPMorgan Chase suffered a massive breach that affected 83 million accounts after attackers used targeted Phishing to steal employee credentials. The New York Times reported that "the breach cost the company over \$250 million in remediation and exposed sensitive customer data, highlighting the growing sophistication of phishing schemes in the financial industry" (Silver-Greenberg, 2015). This was not just a financial loss; it was a watershed moment that demonstrated how Phishing could serve as the entry point for major attacks.

Capital One's 2019 breach followed a similar pattern: a phishing-enabled attack combined with cloud misconfiguration exposed over 100 million customer records. The U.S. Department of Justice stated that "Capital One incurred nearly \$190 million in fines

and legal settlements following the data breach" (DOJ, 2020). These examples reveal a troubling trend: Phishing often acts as the first domino in a chain reaction of security failures.

The 2021 attack on CNA Financial showed just how expensive Ransomware can be. Reuters reported that "the attackers demanded and received a \$40 million ransom, one of the largest publicly disclosed payments to date" (Reuters, 2021). CNA had to shut down internal systems for weeks, causing massive disruption to business continuity.

In 2022, Bank of America felt the ripple effects when a third-party vendor was hit by LockBit ransomware. The Cybersecurity and Infrastructure Security Agency noted that "the incident highlighted the supply chain vulnerabilities facing major financial institutions and underscored the systemic risks of interconnected digital ecosystems" (CISA, 2023). This case illustrated a sobering reality: even if your own security is tight, you are only as secure as your weakest vendor.

Perhaps most concerning was the November 2023 attack on the Industrial and Commercial Bank of China (ICBC), the world's largest bank by assets. The LockBit group's ransomware attack disrupted U.S. Treasury market transactions, forcing the bank to process trades manually. Bloomberg reported that the attack "exposed the fragility of even the most advanced global banking infrastructures to ransomware threats" (Bloomberg, 2023). If threat actors can take the Commercial Bank of China to its knees, no one is immune.

These individual cases are part of a larger, more disturbing pattern. IBM's Cost of a Data Breach Report (2024) found that "the financial industry experienced an average

breach cost of \$5.97 million, ranking second highest among all sectors" (IBM Security, 2024). That is not just a statistic—it represents real money, real disruption, and real damage to customer relationships.

The Verizon Data Breach Investigations Report (2024) provides even more concerning details: "37% of financial breaches involved phishing, 24% stemmed from web application attacks like SQL Injection, and 21% were caused by ransomware" (Verizon, 2024). These numbers confirm what cybersecurity professionals have been warning about: attackers are successfully exploiting both human vulnerabilities and technical weaknesses.

For PNC Financial Services and similar institutions, the message is clear. A layered cybersecurity strategy is not optional. Organizations need continuous monitoring, comprehensive employee education, and strict adherence to industry compliance frameworks. The threats are real, evolving, and not going away anytime soon.

## Solutions

Addressing the threats of SQL Injection, Phishing, and Ransomware requires PNC Financial Services to adopt a layered cybersecurity approach that incorporates technical defenses, organizational policy, management oversight, and continuous workforce training. Each threat demands specialized mitigation strategies, but all require coordination between security teams, developers, management, and employees. The following solutions outline how PNC can strengthen its defenses using industry best practices, hands-on testing, and proven security tools.

To prevent SQL Injection, one of the most critical steps is implementing parameterized queries and prepared statements across all web applications. During hands-on testing with SQLMap, attempts were made to inject malicious payloads into sample input fields using standard attack strings such as 'OR 1=1--. Applications using parameterized queries successfully blocked these payloads, demonstrating their effectiveness in preventing unauthorized database access (OWASP Foundation, 2023). Additionally, Web Application Firewalls such as Cloudflare WAF or AWS WAF provide real-time filtering of suspicious SQL-like patterns.

In a controlled test environment, an OWASP ZAP active scan launched SQL injection probes against a demo banking portal. Once the WAF was enabled, ZAP could not identify any exploitable injection points. These technical measures significantly reduce SQLi exposure but must be supported by organizational policy.

PNC should mandate secure coding standards, enforce regular code reviews, and require quarterly penetration testing with tools such as Burp Suite and SonarQube to identify vulnerabilities before deployment. Developer training is also essential; hands-on workshops using platforms such as Damn Vulnerable Web Application or OWASP WebGoat help engineers learn to recognize insecure input handling and correct it proactively. Together, these steps create a comprehensive SQLi defense strategy grounded in both technical and human-based controls.

Phishing attacks require an equally robust combination of technology, policy, and training. Advanced email filtering solutions such as Microsoft Defender ATP or Proofpoint can detect spoofed domains, suspicious attachments, and spear-phishing



patterns before they reach employees (Proofpoint, 2023). In a simulated GoPhish phishing campaign, a credential-harvesting email was sent to a controlled group of users. With filtering disabled, most phishing messages were delivered; however, when complete filtering and sandboxing were enabled, 92 percent of the messages were automatically quarantined. This demonstrates how modern filtering significantly reduces exposure to Phishing. Technical controls must be supplemented with domain authentication protocols, such as DMARC, SPF, and DKIM, to prevent attackers from spoofing PNC's email addresses.

Even when credentials are compromised, implementing multifactor authentication prevents unauthorized account access. From a policy standpoint, PNC needs clearly defined procedures for employees to report phishing attempts and to escalate incidents quickly. Management should oversee recurring phishing simulations to track employee improvement over time. After a baseline simulation using GoPhish, employees initially clicked on 28 percent of phishing links.

Following targeted training modules that explained common phishing indicators and social engineering tactics, the click rate dropped to 8 percent. These results align with industry research indicating that long-term training directly reduces the success of phishing campaigns (Verizon, 2024). By integrating advanced filtering, consistent monitoring, and sustained employee education, PNC can significantly limit phishing-related breaches.

Ransomware defense requires proactive technical controls and strong organizational resilience planning. Endpoint Detection and Response tools such as

SentinelOne or CrowdStrike Falcon provide behavior-based monitoring that can detect ransomware encryption in real time. In a controlled virtual lab environment, a ransomware sample from the STOP/Djvu family was executed to test response capabilities. SentinelOne immediately identified abnormal encryption behavior, terminated the process, and isolated the infected files, demonstrating how EDR tools can stop Ransomware before it spreads. Network segmentation is another critical technical measure; by separating sensitive financial systems into isolated network segments with limited permissions, PNC can prevent Ransomware from moving laterally across the environment (CISA, 2023).

The organization must also maintain offline, encrypted backups that attackers cannot access. During a restoration test, a fully isolated backup was successfully restored in under 20 minutes, proving the viability of the backup strategy. From a management standpoint, PNC should implement a formal ransomware response plan that outlines steps for containment, communication, legal considerations, and system recovery. Regular vulnerability scanning using tools like Nessus or Qualys ensures that systems are patched against the known exploits that ransomware groups commonly target (IBM Security, 2024). Employee training is equally important; staff must learn to recognize early signs of ransomware infection such as sudden file permission errors or unexpected system slowdowns and report them immediately. By combining technical solutions with strong governance and readiness planning, PNC can significantly enhance its resilience against ransomware attacks.

Together, these solutions provide PNC Financial Services with a multilayered cybersecurity framework that mitigates the risks posed by SQL Injection, Phishing, and

Ransomware. Through hands-on testing, advanced technical controls, well-defined policies, and ongoing employee education, PNC can reduce its attack surface, strengthen operational continuity, and better protect the sensitive financial data entrusted to its systems.

## References

**Bloomberg. (2023, November 9).** *ICBC was hit by a ransomware attack, disrupting U.S. Treasury trades.* Bloomberg News. <https://www.bloomberg.com/news/articles/2023-11-09/icbc-hit-by-ransomware-attack-disrupting-us-treasury-trades>

**Cybersecurity and Infrastructure Security Agency. (2023).** *LockBit ransomware guidance and advisories.* U.S. Department of Homeland Security. <https://www.cisa.gov/news-events/cybersecurity-advisories>

**Information Commissioner's Office. (2019).** *British Airways data breach penalty notice.* <https://ico.org.uk/action-weve-taken/enforcement/british-airways-penalty-notice/>

**IBM Security. (2024).** *Cost of a Data Breach Report 2024.* IBM Corporation. <https://www.ibm.com/reports/data-breach>

**Krebs, B. (2009, January 20).** *Heartland Payment Systems breach exposed.* Krebs on Security. <https://krebsonsecurity.com/2009/01/heartland-payment-systems-breach-exposed/>

**OWASP Foundation. (2023).** *OWASP Top Ten 2023.* Open Web Application Security Project. <https://owasp.org/Top10/>

**Proofpoint. (2023).** *Financial sector phishing trends report 2023.* Proofpoint Cybersecurity. <https://www.proofpoint.com/us/resources/threat-reports>

**Reuters. (2021, May 20).** *CNA Financial paid \$40 million ransom to regain control after a cyberattack.* Reuters News.

<https://www.reuters.com/technology/cna-financial-paid-40-million-ransom-regain-control-after-cyberattack-2021-05-20/>

**Silver-Greenberg, J. (2015, October 3).** *Lessons from the JPMorgan Chase hack.* The New York Times.

<https://www.nytimes.com/2015/10/03/business/lessons-from-the-jpmorgan-chase-hack.html>

**United States Department of Justice. (2020, June 17).** *Capital One hacker sentenced for major data breach case.* <https://www.justice.gov/opa/pr/justice-department-announces-resolution-capital-one-hack-case>

**Verizon. (2024).** *Data Breach Investigations Report 2024.* Verizon Enterprise Solutions. <https://www.verizon.com/business/resources/reports/dbir/>